

Axiom AI Technologies

Security Governance Framework

Document Reference: AAX-GOV-2026-001

Version: 1.0

Classification: Internal Use

Status: Approved – Portfolio Case Study

Document Owner: Information Security / ISMS Owner

Framework Owner: Security Governance / GRC

Effective Date: October 2026

Review Frequency: Annual or upon significant change

1. Purpose

The purpose of this Security Governance Framework is to establish the structure, accountability, decision-making processes, and oversight mechanisms used to govern information security at Axiom AI Technologies.

The framework establishes how information-security responsibilities are assigned, how risks and security decisions are escalated, how security policies and exceptions are governed, and how management monitors the effectiveness of the Information Security Management System (ISMS).

The framework is intended to ensure that information security supports Axiom AI's business objectives while maintaining appropriate confidentiality, integrity, availability, and regulatory and contractual obligations.

2. Scope

This framework applies to the governance of Axiom AI's information-security program and ISMS.

It covers:

- Information-security governance
- ISMS accountability
- Security roles and responsibilities

- Risk governance
- Risk acceptance
- Security exceptions
- Policy governance
- Security objectives
- Security reporting
- Key Performance Indicators (KPIs)
- Key Risk Indicators (KRIs)
- Compliance oversight
- Internal assessment
- Management review
- Corrective actions
- Continual improvement

The framework applies to relevant personnel, contractors, systems, processes, and third parties within the organization's ISMS scope.

3. Governance Principles

Axiom AI's security governance program is based on the following principles.

3.1 Accountability

Information-security responsibilities shall be assigned to appropriate individuals or functions.

Personnel with security responsibilities are accountable for performing those responsibilities and reporting material issues.

3.2 Risk-Based Decision Making

Security decisions shall consider:

- Business impact
- Threat exposure
- Vulnerability
- Likelihood
- Existing controls
- Residual risk
- Cost and feasibility of treatment

3.3 Evidence-Based Governance

Security decisions and compliance claims should be supported by appropriate, current, and traceable evidence.

3.4 Management Oversight

Material security risks, control weaknesses, incidents, compliance gaps, and security-performance trends shall be communicated to appropriate management.

3.5 Proportionality

Security controls and governance processes should be proportionate to the organization's risk profile, business requirements, and technology environment.

3.6 Separation of Responsibilities

Where practical, responsibility for implementing controls, assessing effectiveness, and approving significant risk decisions should be appropriately separated.

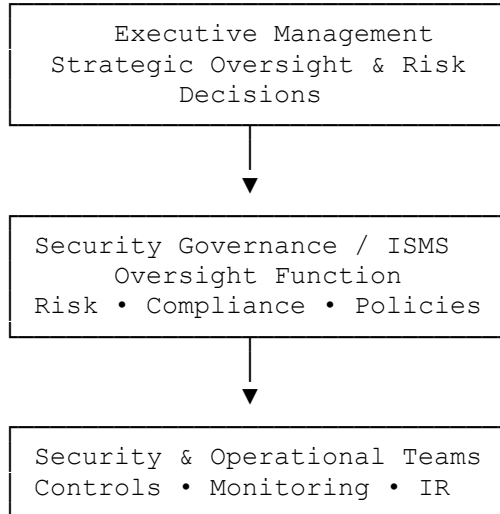
3.7 Continual Improvement

The ISMS shall be continually improved using information from:

- Risk assessments
 - Security incidents
 - Vulnerability management
 - Internal assessments
 - External audits
 - BCP exercises
 - Third-party assessments
 - Management reviews
 - Security metrics
 - Lessons learned
-

4. Governance Structure

Axiom AI's security governance model consists of three primary levels:



The governance model establishes accountability from executive management through operational security functions.

5. Executive Management Responsibilities

Executive Management provides strategic direction and oversight for information security.

Responsibilities include:

- Approving information-security objectives.
- Reviewing significant information-security risks.
- Approving material risk acceptance decisions.
- Providing appropriate resources.
- Reviewing security-performance information.
- Reviewing significant incidents.
- Reviewing material compliance issues.
- Supporting continual improvement.
- Ensuring security objectives remain aligned with business objectives.

Executive Management should receive security information in a format that supports informed decision-making.

6. ISMS Owner Responsibilities

The ISMS Owner is responsible for coordinating the effectiveness and continual improvement of the ISMS.

Responsibilities include:

- Maintaining the ISMS framework.
- Coordinating risk-management activities.
- Coordinating control assessments.
- Monitoring ISMS performance.
- Coordinating management reviews.
- Supporting internal and external audits.
- Maintaining ISMS documentation.
- Coordinating corrective actions.
- Monitoring security objectives.
- Escalating significant security matters.
- Coordinating continual-improvement activities.

The ISMS Owner does not independently accept organizational risk on behalf of management unless formally delegated that authority.

7. Security/GRC Responsibilities

The Security/GRC function supports the governance and oversight of the information-security program.

Responsibilities include:

- Risk-register management
- Security-control assessments
- Compliance monitoring
- Policy governance
- Audit preparation
- Security reporting
- KPI/KRI development
- Corrective-action tracking
- Third-party risk coordination
- Security evidence management
- Governance documentation

The Security/GRC function provides management with visibility into the organization's security posture.

8. Security Operations Responsibilities

Security Operations and technical security personnel are responsible for implementing and operating appropriate security controls.

Responsibilities include:

- Security monitoring
- Vulnerability management
- Incident detection
- Incident response
- Endpoint protection
- Logging and monitoring
- Security configuration
- Threat investigation
- Technical remediation
- Evidence preservation

Operational personnel shall escalate material security issues according to established procedures.

9. Risk Owner Responsibilities

Each material security risk should have an assigned risk owner.

Risk owners are responsible for:

- Understanding the assigned risk.
- Reviewing the risk rating.
- Evaluating treatment options.
- Supporting remediation.
- Monitoring residual risk.
- Escalating material changes.
- Requesting risk acceptance where appropriate.
- Confirming that treatment decisions remain appropriate.

Risk ownership should normally reside with the business or operational function capable of managing the underlying risk.

10. Control Owner Responsibilities

Control owners are responsible for the operation and maintenance of assigned controls.

Responsibilities include:

- Implementing controls.
- Maintaining control procedures.
- Monitoring control performance.
- Maintaining supporting evidence.
- Addressing control deficiencies.
- Supporting control testing.
- Reporting control failures.
- Supporting remediation activities.

Control owners should be able to demonstrate that controls operate as documented.

11. Internal Audit and Assessment Responsibilities

Internal assessment activities should provide an appropriate level of independent evaluation.

Assessors may:

- Review policies.
- Examine control evidence.
- Evaluate control effectiveness.
- Review risk treatment.
- Identify gaps.
- Validate corrective actions.
- Report findings to appropriate management.

Where practical, individuals should not independently assess controls for which they have direct operational responsibility.

12. Responsibility Matrix

The following matrix establishes high-level accountability.

Activity	Executive Management	ISMS Owner	Security/GRC	Operational Teams	Risk Owner
Security Strategy	A	R	C	C	C
ISMS Management	A	R	R	C	C
Risk Identification	C	A	R	R	R
Risk Treatment	A	C	R	R	R
Risk Acceptance	A	C	C	C	R
Control Implementation	C	C	C	R	C
Control Assessment	C	A	R	C	C
Security Monitoring	C	C	C	R	C
Incident Response	A	C	C	R	C
Policy Governance	A	R	R	C	C
Compliance Assessment	C	A	R	C	C
Management Review	A	R	R	C	C
Continual Improvement	A	R	R	R	C

R = Responsible

A = Accountable

C = Consulted

13. Security Objectives

Axiom AI shall establish information-security objectives that support business priorities and identified risks.

Example objectives include:

1. Reduce unresolved High and Critical security risks.

2. Maintain effective security controls.
3. Improve vulnerability remediation performance.
4. Improve incident detection and response.
5. Maintain business continuity readiness.
6. Improve compliance evidence quality.
7. Maintain timely policy reviews.
8. Improve security awareness and accountability.
9. Reduce recurring security findings.
10. Continually improve the ISMS.

Where practical, objectives should be measurable and assigned to accountable owners.

14. Security Risk Governance

Security risks shall be managed through a defined lifecycle:

```
Identify
↓
Analyze
↓
Evaluate
↓
Treat
↓
Monitor
↓
Report
↓
Review
```

Risk treatment options may include:

- Mitigation
- Avoidance
- Transfer
- Acceptance

Risk decisions should be documented in the organization's risk register.

15. Risk Acceptance

Risk acceptance shall be treated as a formal management decision.

A risk-acceptance record should include:

- Risk identification
- Risk description
- Affected asset or process
- Inherent risk
- Existing controls
- Residual risk
- Business justification
- Compensating controls
- Risk owner
- Approval authority
- Acceptance date
- Expiration or review date

High and Critical residual risks should receive appropriate management approval.

Risk acceptance shall not be used as a substitute for reasonable remediation without documented justification.

16. Security Exceptions

Security exceptions may be granted when a security requirement cannot reasonably be implemented as defined.

An exception request shall include:

- Requirement being excepted
- Business justification
- Affected system or process
- Security implications
- Risk assessment
- Compensating controls
- Exception owner
- Approval authority
- Expiration date
- Review requirements

Exceptions should be:

- Documented
- Approved
- Time-bound
- Periodically reviewed

Expired exceptions shall be reassessed rather than automatically renewed.

17. Policy Governance

Information-security policies shall follow a controlled lifecycle.

Draft
↓
Review
↓
Approval
↓
Publication
↓
Implementation
↓
Monitoring
↓
Periodic Review
↓
Revision / Retirement

Controlled security documents should include:

- Document title
- Document reference
- Version
- Classification
- Owner
- Approval authority
- Effective date
- Review frequency
- Status
- Revision history

Policies should be reviewed following significant changes to:

- Organizational structure
- Technology

- Business processes
 - Security risks
 - Legal or contractual requirements
 - Applicable standards
-

18. Security Reporting

Security reporting shall provide management with meaningful information about the organization's security posture.

Reporting should include, where relevant:

- Risk trends
- Control effectiveness
- Open audit findings
- Vulnerability trends
- Security incidents
- Third-party risk
- Business continuity activities
- Compliance status
- Corrective actions
- Security objectives
- KPIs
- KRIs

Management reporting should highlight:

- Significant changes
 - Emerging risks
 - Material control failures
 - Overdue actions
 - Decisions requiring management approval
-

19. Key Performance Indicators

Axiom AI should use KPIs to evaluate security-program performance.

Examples include:

KPI	Measurement	Purpose
Control Assessment Completion	% completed	Measures assessment coverage
Remediation SLA Compliance	% within SLA	Measures remediation performance
Security Training Completion	% completed	Measures awareness
Policy Review Completion	% reviewed on time	Measures governance maintenance
BCP Exercise Completion	% completed	Measures continuity readiness
Corrective Action Closure	% completed	Measures improvement progress

Metrics should be reviewed over time to identify trends rather than evaluated solely as individual data points.

20. Key Risk Indicators

KRIs provide management with visibility into increasing security exposure.

Examples include:

KRI	Potential Warning Signal
Overdue High/Critical Vulnerabilities	Increasing technical exposure
Overdue Risk Treatments	Increasing residual risk
High-Risk Open Findings	Persistent control weaknesses
Security Incident Volume	Increasing threat activity
Repeat Findings	Ineffective remediation
Critical Third-Party Issues	Supplier exposure
Failed Recovery Tests	Increased continuity risk

KRI thresholds should be established according to organizational risk appetite.

21. Escalation and Decision-Making

Security matters shall be escalated when they exceed defined thresholds or require management decisions.

Examples include:

- Critical security incidents
- High or Critical residual risks
- Significant control failures
- Material compliance gaps
- Suspected significant data exposure
- Major third-party security events
- Repeated remediation failures
- Major business-continuity concerns

Escalation records should identify:

1. Issue
2. Affected asset or process
3. Business impact
4. Risk
5. Existing controls
6. Recommended action
7. Decision required
8. Decision owner
9. Target date

22. Compliance Governance

Compliance shall be managed as an ongoing process rather than a point-in-time audit exercise.

The compliance lifecycle is:

```
Identify Requirements
    ↓
Map Requirements to Controls
    ↓
Collect Evidence
    ↓
Assess
    ↓
Identify Gaps
    ↓
```

Assign Actions



Remediate



Validate



Report



Monitor

Compliance activities should be aligned with:

- Organizational policies
- ISO/IEC 27001
- Applicable contractual requirements
- Applicable regulatory requirements
- Relevant security frameworks

Formal legal or regulatory determinations should be performed by appropriate qualified personnel.

23. Evidence Governance

Security evidence shall be maintained in a manner that supports:

- Traceability
- Integrity
- Availability
- Appropriate access control
- Auditability
- Retention requirements

Examples of evidence include:

- Policies
- Risk registers
- Statements of Applicability
- Control assessments
- Vulnerability reports
- Remediation records
- Incident records
- BCP documentation
- Tabletop exercise records
- Audit reports
- Security metrics

- Management-review records

Evidence should be sufficiently current to support the assertion being made.

24. Internal Assessment

The ISMS should undergo periodic assessment to determine whether:

- Security controls are implemented.
- Controls operate as intended.
- Policies remain appropriate.
- Risks are being managed.
- Security objectives are progressing.
- Corrective actions are effective.
- Compliance obligations are being monitored.

Assessment findings should be documented and tracked to closure.

25. Management Review

Management shall periodically review the ISMS to determine whether it remains:

- Suitable
- Adequate
- Effective
- Aligned with business objectives

Management-review inputs should include:

- Previous management-review actions
- Changes affecting the ISMS
- Risk-management results
- Security objectives
- Security incidents
- Audit findings
- Control performance
- Vulnerability trends
- Compliance status
- Third-party risks
- Business-continuity results

- Security metrics
- Improvement opportunities

Management-review outputs should include documented decisions and actions.

A dedicated Management Review Report is maintained separately under:

06-security-governance-compliance/03-management-review/

26. Continual Improvement

Axiom AI shall continually improve the suitability, adequacy, and effectiveness of its ISMS.

Improvement opportunities may originate from:

- Security incidents
- Audit findings
- Risk assessments
- Vulnerability trends
- Control assessments
- BCP exercises
- Compliance assessments
- Third-party assessments
- Management reviews
- Employee feedback
- Lessons learned

Improvement actions should be prioritized according to risk and business impact.

27. Corrective Actions

Corrective actions shall address the underlying cause of identified security or compliance deficiencies where appropriate.

Corrective-action records should include:

- Finding
- Root cause
- Corrective action
- Action owner

- Priority
- Target date
- Status
- Evidence
- Validation result
- Closure date

Actions should be validated before being considered fully closed where validation is appropriate.

28. Third-Party Governance

Third-party security risks shall be governed through the organization's supplier-risk process.

Governance activities may include:

- Security due diligence
- Security questionnaires
- Contractual requirements
- Risk classification
- Security reviews
- Evidence collection
- Incident notification requirements
- Periodic reassessment
- Remediation tracking

Material third-party security risks should be escalated to appropriate management.

29. Security Awareness and Accountability

All personnel are responsible for complying with applicable information-security requirements.

Personnel should:

- Follow security policies.
- Protect organizational information.
- Report suspected security incidents.
- Complete required security training.
- Protect credentials.
- Follow approved procedures.
- Escalate security concerns.

Management is responsible for reinforcing security accountability within their respective functions.

30. Governance Review Cycle

The governance framework shall be reviewed at least annually and following significant changes.

A review should consider:

- Organizational changes
- Changes in business strategy
- Changes in technology
- Emerging threats
- Changes in risk exposure
- Security incidents
- Audit findings
- Regulatory or contractual changes
- Changes to the ISMS
- Lessons learned

Updates shall be documented through the organization's document-control process.

31. ISO/IEC 27001 Alignment

This framework supports relevant requirements of ISO/IEC 27001:2022, including:

Clause 5 — Leadership

Supports:

- Leadership commitment
- Information-security policy
- Organizational roles and responsibilities

Clause 6 — Planning

Supports:

- Risk management

- Security objectives
- Planning for changes

Clause 9 — Performance Evaluation

Supports:

- Monitoring
- Measurement
- Internal audit
- Management review

Clause 10 — Improvement

Supports:

- Nonconformity and corrective action
- Continual improvement

Relevant Annex A controls may include:

- A.5.1 — Policies for information security
- A.5.2 — Information security roles and responsibilities
- A.5.4 — Management responsibilities
- A.5.7 — Threat intelligence
- A.5.24–A.5.28 — Incident management
- A.5.35 — Independent review of information security
- A.5.36 — Compliance with policies, rules and standards
- A.5.37 — Documented operating procedures
- A.8.7 — Protection against malware
- A.8.15 — Logging
- A.8.16 — Monitoring activities

Applicability shall be determined through the organization's Statement of Applicability.

32. Governance Maturity

Axiom AI should progressively improve its security governance maturity.

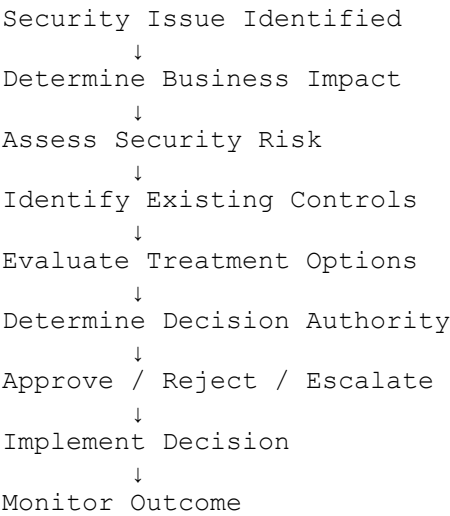
A simplified maturity model is:

Level	Description
1 — Initial	Ad hoc security activities
2 — Developing	Basic policies and responsibilities established
3 — Defined	Documented governance processes operating
4 — Managed	Metrics and management oversight established
5 — Optimized	Continual improvement and proactive governance

The target state is a **Managed to Optimized** governance model appropriate to the organization's size, risk profile, and business requirements.

33. Governance Decision Framework

Security decisions should follow a structured process:



This approach promotes consistency and reduces the likelihood of undocumented security decisions.

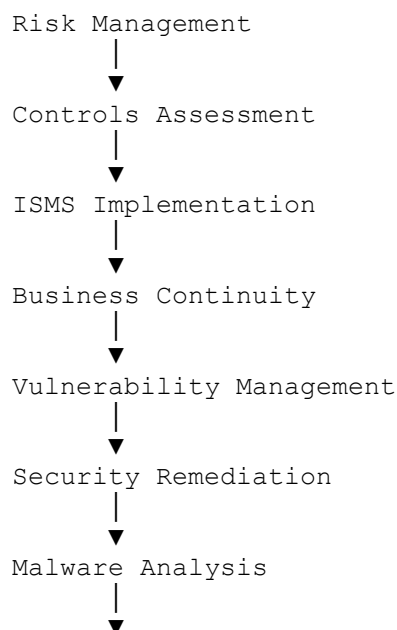
34. Governance Records

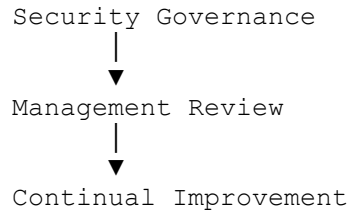
The following records should be maintained as part of the governance program:

Record	Owner
Security Policies	ISMS Owner
Risk Register	Security/GRC
Risk Acceptance Records	Risk Owner
Security Exceptions	Control/Process Owner
Control Assessments	Security/GRC
Audit Findings	Security/GRC
Corrective Actions	Action Owner
Security Metrics	Security/GRC
Management Reviews	ISMS Owner
Security Objectives	ISMS Owner
BCP/DR Records	Business Continuity Owner
Incident Records	Security Operations
Third-Party Assessments	Security/GRC / Procurement

35. Relationship to the Axiom AI Security Program

This framework provides governance oversight for the security activities established throughout the broader Axiom AI case study.





The governance function provides the management structure necessary to monitor these activities and make informed security decisions.

36. Governance Effectiveness Criteria

The governance framework should be considered effective when:

- Security responsibilities are clearly assigned.
 - Material risks have accountable owners.
 - Significant risks are escalated appropriately.
 - Management receives meaningful security reporting.
 - Security policies are maintained and reviewed.
 - Exceptions are controlled and time-bound.
 - Corrective actions are tracked.
 - Security objectives are monitored.
 - Compliance evidence is maintained.
 - Management reviews occur as planned.
 - Continual-improvement activities are documented.
-

37. Final Governance Statement

Axiom AI's security governance framework establishes the accountability, oversight, and decision-making structure required to manage information security as an organizational responsibility.

The framework connects executive management, GRC, security operations, engineering, risk owners, and control owners through defined responsibilities and escalation mechanisms.

Effective governance ensures that information-security decisions are:

- Risk-based
- Evidence-based
- Accountable
- Documented

- Measurable
- Aligned with business objectives

The framework is intended to support an effective and continually improving ISMS while providing management with appropriate visibility into the organization's security posture.

38. Document Control

Field	Value
Document Title	Axiom AI Security Governance Framework
Document Reference	AAX-GOV-2026-001
Version	1.0
Classification	Internal Use
Status	Approved – Portfolio Case Study
Document Owner	Information Security / ISMS Owner
Framework Owner	Security Governance / GRC
Effective Date	October 2026
Review Frequency	Annual or upon significant change
Next Review	October 2027

39. Revision History

Version	Date	Description	Author
1.0	October 2026	Initial governance framework	Security Governance / GRC

40. Portfolio Disclaimer

This document is a simulated cybersecurity and GRC case study created for professional portfolio purposes.

Axiom AI Technologies is a fictional organization. All organizational information, roles, metrics, findings, assessments, evidence, decisions, and recommendations are simulated.

The framework demonstrates practical knowledge of security governance, GRC, ISMS management, risk governance, compliance oversight, management reporting, and continual improvement.

It does not represent a formal certification audit, legal compliance determination, or assessment of a real organization.

